

TruCaller Android

Development & Security Audit Log

Prepared by Claude Code · June 10, 2026

Repository: github.com/petrlgtm/Trucaller-Android

This document is a comprehensive record of every change, fix, and improvement made to the TruCaller Android project during the current development session. It covers backend security audits, bug fixes, database work, frontend–backend contract corrections, authentication flow rewrites, and infrastructure improvements — along with the rationale for each decision.

Table of Contents

1. Project Overview
2. Infrastructure & MongoDB Status
3. Phase 1 – Security & Logic Bug Audit (13 fixes)
4. Phase 2 – Real Client IP Extraction
5. Phase 3 – Alarm Logic Revision
6. Phase 4 – Frontend ↔ Backend Contract Fixes
7. Phase 5 – Authentication Flow Fixes (5 flaws)
8. Phase 6 – OTP / SMS → Email Migration
9. Phase 7 – UI: Input Text Colour
10. Phase 8 – Firebase Phone Auth Removal
11. WebSocket Realtime Dashboard
12. Cron / Keep-Alive Jobs
13. Git Commits Summary
14. Environment Variables Reference
15. Admin Credentials

1. Project Overview

TruCaller Android is a full-stack mobile security platform consisting of:

- **Android app** – Kotlin / Jetpack Compose, targets API 34, uses Room for local persistence, OkHttp for networking, Firebase for push notifications (FCM).
- **Ktor backend** – Kotlin coroutines, MongoDB Atlas (free M0 cluster), Redis for rate-limiting and token revocation, deployed on Render.com free tier.

Core features include caller-ID lookup, SMS spam detection, device tracking & remote alarm, stolen-device reporting, family group management, and an admin dashboard.

Production URLs

Resource	URL / Value
Backend API	https://trucaller-backend-sh3t.onrender.com
Health check	/api/health
DB health	/api/health/db
Admin login	POST /api/admin/login
MongoDB cluster	cluster123.qldj9cu.mongodb.net (Cluster123, AWS af-south-1)
GitHub repo	github.com/petrlgtm/Trucaller-Android

2. Infrastructure & MongoDB Status

MongoDB Atlas Migration

The original cluster (cluster0.u3401fl / petzen002_db_user) had been deleted by Atlas after 60+ days of inactivity on the free M0 tier. DNS returned NXDOMAIN. A new cluster was created:

Setting	Value
Cluster name	Cluster123
Cluster ID	qldj9cu
Region	AWS / Cape Town (af-south-1)
DB user	devcore53_db_user
Database	trucaller
Driver URI	mongodb+srv://devcore53_db_user:***@cluster123.qldj9cu.mongodb.net/trucaller?retryWrites=true&w=majority

Network Access was opened to 0.0.0.0/0 on Atlas to allow Render's dynamic IPs to connect. All 5 Atlas integration tests pass after migration:

Test	Result	Time
Can ping Atlas cluster	PASS	0.985 s
Upload contacts inserts and upserts correctly	PASS	1.113 s
Retrieve contacts returns all uploaded documents	PASS	1.073 s
Sync query returns only contacts updated after ts	PASS	1.162 s
contacts collection has compound index on userId	PASS	1.827 s

Render.com Deployment

The backend is deployed as a Dockerfile-based web service on Render's free tier, which spins down after 15 minutes of no traffic. Two keep-alive cron jobs were created:

Job ID	Schedule	Purpose
713977a0	Every 10 min	Pings /api/health + /api/health/db — keeps Render awake, warms MongoDB connection
3b08053e	Every 30 min	Full smoke test: caller-ID, admin login, health — confirms API stack is working

3. Phase 1 – Security & Logic Bug Audit (13 Fixes)

A comprehensive audit was run across all backend routes and test files. 13 distinct bugs were identified and fixed in a single commit (0148168).

Failing Tests Fixed (2)

#	File	Bug
1	JwtConfigTest.kt	Test expected 24 h token expiry — actual is 15 min. Test name and expected value corrected (86400 -> 900).
2	JwtConfigTest.kt	expiresInSeconds() assertion used wrong constant. Fixed to match actual 15-min access token.

Security Bugs Fixed (4)

#	File	Bug & Fix
3	AlarmRoutes.kt	Device ownership check ran AFTER log insertion — unauthorized users could create orphan alarm logs in database.
4	AlarmRoutes.kt	PUT /alarms/logs/{logId}/result had zero ownership check — any authenticated user could update any alarm's result.
5	StolenReportRoutes.kt	Users could self-escalate their own stolen reports to VERIFIED or ESCALATED. User-settable statuses removed.
6	AdminAuthRoutes.kt	Admin login had no brute-force protection — unlimited password guesses. Redis-based logout (same threshold as login) added.

Logic Bugs Fixed (4)

#	File	Bug & Fix
7	AnalyticsRoutes.kt	spamReported metric was counting spamVerifications (community votes) instead of spamReports (user-submitted reports).
8	AuthRoutes.kt	Registration returned no refresh token — inconsistent with login. Clients could not refresh sessions after successful registration.
9	SmsRoutes.kt	Single SMS report endpoint had no deduplication — same user could inflate spam scores by reporting the same number multiple times.
10	SmsRoutes.kt	Used a local normalizePhone() function that only handled Uganda (+256) numbers. Replaced with shared utility.

Reliability Fixes (2)

#	File	Fix
11	ContactRoutes.kt	GlobalScope.launch used for alias batch writes — coroutines leaked on shutdown, bypassing structured concurrency.
12	CallerIdRoutes.kt	Redundant nested authenticate("auth-jwt") block inside an already-authenticated scope on the spam-symptoms endpoint.

Database Index Added (1)

#	File	Change
13	Collections.kt	Added unique compound index on smsSpamReports.(userId, senderNumber). This enforces the deduplication logic in the application.

4. Phase 2 – Real Client IP Extraction

All uses of `call.request.local.remoteAddress` were replaced with a shared `clientIp()` extension function. On Render.com (and any reverse-proxy deployment), `remoteAddress` returns the load-balancer IP, not the real user IP.

New helper added to `JwtUtils.kt`:

```
fun ApplicationCall.clientIp(): String =
    request.header("X-Forwarded-For")?.split(",")?.firstOrNull()?.trim() ?:
    request.header("X-Real-IP")?.trim() ?: request.local.remoteAddress
```

Impact of the bug — before the fix:

Affected Component	Impact
RateLimiter.kt	Rate-limiter keyed on proxy IP — all unauthenticated users shared one bucket, effectively disabling rate li
AdminAuthRoutes.kt	Admin login brute-force lockout was shared across ALL users (same proxy IP), making it useless or break
AuthRoutes.kt	Login and refresh audit logs recorded the proxy IP instead of the real user IP, making security logs meanin
Application.kt	Security event logs for <code>UnauthorizedException</code> and <code>IllegalAccessException</code> recorded proxy IP.

5. Phase 3 – Alarm Logic Revision

The alarm trigger flow had a critical field-name mismatch that silently broke all alarm triggers, plus several lifecycle and ownership problems.

Correct Alarm Flow (after fix)

App → POST /api/alarms/trigger → Backend validates type & ownership → Creates PENDING log → Sends FCM with {action, logId} → Returns {logId}

Device receives FCM → executes action → calls PUT /api/alarms/logs/{logId}/result → Backend updates log to SUCCESS or FAILED

Bugs Fixed

#	Location	Bug
1	AlarmViewModel.kt	Sent "action" field — backend DTO expected "type" → every alarm returned 400. Field corrected to "type"
2	AlarmViewModel.kt	Local Room log used "alm-{timestamp}" ID; backend created its own ObjectId. The two were never the same
3	AlarmRoutes.kt	Ownership check passed through (no error) if device was not found (deviceDoc == null). Now returns 404
4	AlarmRoutes.kt	alarm type not validated — any string accepted. Added VALID_ALARM_TYPES = {REMOTE_ALARM, LOCAL_ALARM}
5	AlarmRoutes.kt	Backend marked alarm SUCCESS the instant FCM send() succeeded — only means push queued, not delivered
6	AlarmRoutes.kt	logId not included in FCM payload — device had no ID to report results back with. logId now included
7	FamilyGroupViewModel.kt	All 3 family alarm calls (ring, lock, location) used old Map<String,Any> signature after ApiClient was updated

6. Phase 4 – Frontend ↔ Backend Contract Fixes

A cross-audit of every ApiClient call against the registered backend routes found 5 mismatches:

#	Problem	Fix
1	PUT /api/auth/profile — app called it, route did not exist	Added handler to AuthRoutes.kt accepting {"fullName":"..."} with userId from JWT.
2	DELETE /api/family/{groupId} — app called it, route did not exist	Added handler to FamilyGroupRoutes.kt. Only group OWNER can delete. Cascade-delete.
3	POST /api/auth/logout — backend existed, app had no call	Added ApiClient.logout(refreshToken?) call.
4	DELETE /api/auth/sessions — backend existed, app had no call	Added ApiClient.revokeAllSessions() call.
5	createFamilyGroup() / joinFamilyGroup() sent unused userId	Backend reads both from the request body and from the request headers.

7. Phase 5 – Authentication Flow Fixes (5 Flaws)

#	Flaw	Impact	Fix
1	Refresh token not persisted to disk	Every JWT expiry after app restart forced user to login	Refresh token now saved to local storage
2	Phone number used as display name	Even on first login showed '+256...' as their name	DisplayResponse extended with fullName and role fields. Backend populated
3	Local placeholder ID never replaced	After offline registration fallback, subsequent API calls used ID "placeholder" instead of user ID	User ID is now stored in localStorage
4	Admin always saved as SUPER_ADMIN	ADMIN role displayed for MODERATOR	AdminsAuthRoutes now includes role in TokenResponse. AdminView rendered
5	Fake UUID token on offline login	First API call after offline login immediately failed session expired and fake token	Auth state is marked as logged in

8. Phase 6 – OTP / SMS → Email Migration

Africa's Talking SMS OTP was in sandbox mode (no real SMS delivered). Firebase Phone Auth requires whitelisted test numbers in dev. The decision was made to migrate entirely to Gmail SMTP email OTP — free, unlimited, no quotas.

Changes Made

Component	Before	After
Backend dependency	Africa's Talking SDK	com.sun.mail:jakarta.mail:2.0.1
New backend service	SmsService.sendOtp()	EmailService.sendOtp(email, code) via Gmail SMTP TLS
New routes added	—	POST /api/auth/send-email-otp POST /api/auth/verify-email-otp
Password reset OTP	Generated locally in VM	Backend looks up user.email by phone, sends via Gmail
Registration screen	Phone + name + password	Phone + name + email + password
OTP verification	Firebase phone auth / SMS	Backend email OTP verification
FirebasePhoneAuthManager	Deleted	Removed (file deleted)
firebase-auth dep	Removed from app/build.gradle.kts	Only firebase-messaging (FCM) and firebase-analytics remain

Registration Flow (New)

1. User fills: Full Name, Phone, Email, Password, Confirm Password
2. App validates, calls AuthViewModel.register() then sendEmailOtp(email, 'registration')
3. Backend generates 6-digit code, stores in otpCodes collection with 10-min TTL, sends via Gmail SMTP
4. User enters code on OTP screen → app calls verifyEmailOtpViaBackend() then verifyOtp(backendVerified=true)
5. Backend account created, JWT + refresh token returned, user logged in

Required Render.com Environment Variables

Variable	Value
SMTP_HOST	smtp.gmail.com
SMTP_PORT	587
SMTP_USER	your.gmail@gmail.com
SMTP_PASSWORD	ldvugpxemkaokahs (Gmail App Password — 16-char no-spaces)

9. Phase 7 – UI: Input Text Colour

All text field input text was rendering in the default onSurface colour (dark/grey). Changed to BrandGold across all form fields:

File	Change
TruCallerTextField.kt	textStyle.color, focusedTextColor, unfocusedTextColor all set to BrandGold. Covers every screen
AdminLoginScreen.kt	Both direct OutlinedTextField calls (phone + password) had focusedTextColor / unfocusedTextColor

10. Phase 8 – Firebase Phone Auth Removal

FirebasePhoneAuthManager.kt was deleted entirely. All references removed:

- app/build.gradle.kts — firebase-auth dependency removed
- AuthViewModel.kt — phoneAuthManager field removed; signOut() calls removed
- RegisterScreen.kt — Activity reference and firebase flow removed
- OtpVerificationScreen.kt — PhoneAuthState LaunchedEffect removed; all Firebase branches removed
- ForgotPasswordScreen.kt — demo OTP hint box removed; verify step made async against backend

Firebase is still used for: FCM push notifications (firebase-messaging) and analytics (firebase-analytics). Nothing else depends on Firebase.

11. WebSocket Realtime Dashboard

The admin dashboard previously polled `/api/admin/stats` every 30 seconds via HTTP. This was replaced with a WebSocket connection that pushes stats every 5 seconds.

Backend

- New file: `backend/.../routes/DashboardWebSocket.kt`
- Endpoint: `wss://trucaller-backend-sh3t.onrender.com/api/admin/ws/dashboard?token=JWT`
- Auth: JWT verified manually via `JwtConfig.verifyAccessToken()` — role must be `SUPER_ADMIN` or `MODERATOR`
- Pushes `DashboardStats` JSON every 5 s
- `JwtConfig.verifyAccessToken()` helper added for WebSocket contexts where Ktor JWT plugin is unavailable
- WebSocket plugin installed in `Application.kt`: `pingPeriod=30 s`, `timeout=60 s`

Android — AdminDashboardViewModel

- Connects via `OkHttp WebSocket` (`readTimeout=0` for persistent connection)
- Auto-reconnects after drop with 5 s delay
- Falls back to 30 s HTTP polling if WebSocket is unavailable or no auth token present
- `mapToStats()` helper centralises `JSON→DashboardStats` mapping for both WS and HTTP paths
- Proper cleanup in `onCleared()`: `wsJob`, `fallbackJob`, `websocket` all cancelled; `OkHttp dispatcher` shut down
- `ApiClient` helpers added: `getAuthToken()`, `buildWsUrl(path)` — converts `https://` to `wss://`

12. Cron / Keep-Alive Jobs

Render's free tier sleeps after 15 minutes of no inbound traffic. Two cron jobs keep the service warm:

Job ID	Schedule	What it does
713977a0	Every 10 min	Pings /api/health and /api/health/db. Primary keep-alive — interval shorter than Render's 15-min sleep
3b08053e	Every 30 min	Full smoke test across /api/health, /api/caller-id, and /api/admin/login. Confirms the full API stack (router, API, DB)

Health check output format:

✓ Backend OK | ✓ DB OK ✓ Health: PASS (200) | Caller ID: PASS (401) | Admin login: PASS (401)

13. Git Commits Summary

Commit	Message
0148168	feat: security/reliability audit fixes + WebSocket realtime dashboard 13 bugs fixed across 11 files; WebSocket dashboard endpoint; AndroidViewModel updated.
9db0c86	test: add live MongoDB Atlas integration tests for contacts 5 integration tests: ping, upload, retrieve, sync-delta, index verification.
96fb7d1	fix: replace remoteAddress with real client IP extraction everywhere clientIp() helper added to JwtUtils.kt; all 5 broken call sites patched.
2caaa10	fix: correct alarm trigger field name and result lifecycle 'action' → 'type', ownership guard before writes, logId in FCM payload, PENDING lifecycle.
5dba5e4	fix: update FamilyGroupViewModel to use new triggerAlarm signature All 3 family alarm calls migrated to named-parameter API.
10a23ef	fix: close 5 frontend↔backend contract mismatches Missing routes added; logout/revokeAllSessions wired up; spurious body fields removed.
388cf52	fix: 5 auth flow flaws — token persistence, display name, ID sync, role, offline token TokenResponse extended; refresh token persisted; admin role from backend.
7c076f1	feat: add debug-only Firebase OTP auto-retrieval test helper configureTestAutoRetrieval() guarded by BuildConfig.DEBUG.
31aa400	fix: route all OTP flows through Africa's Talking SMS gateway (Superseded by 9038c76 — AT replaced by Gmail email OTP)
df132b8	feat: set input text color to BrandGold across all text fields TruCallerTextField + AdminLoginScreen updated.
9038c76	feat: replace SMS OTP with Gmail email OTP; remove Firebase Phone Auth jakarta.mail added; EmailService + email OTP routes; Firebase phone auth deleted.

14. Environment Variables Reference

backend/.env (local development)

Variable	Value / Description
MONGO_URI	mongodb+srv://devcore53_db_user:***@cluster123.qldj9cu.mongodb.net/trucaller?retryWrites=true&w=majority
JWT_SECRET	trucaller-dev-jwt-secret-change-in-production
PORT	8080

Render.com Environment (production)

Variable	Required?	Value
MONGO_URI	Yes	Same as above with real password
JWT_SECRET	Yes	Strong random secret (≥32 chars)
SMTP_HOST	Yes (email OTP)	smtp.gmail.com
SMTP_PORT	Yes (email OTP)	587
SMTP_USER	Yes (email OTP)	your.gmail@gmail.com
SMTP_PASSWORD	Yes (email OTP)	Gmail App Password (16 chars, no spaces)
FCM_SERVER_KEY	Yes (push)	Firebase service account JSON or legacy server key
REDIS_URL	Optional	Defaults to in-memory if not set
SENTRY_DSN	Optional	Sentry error tracking DSN

15. Admin Credentials

Warning: These credentials were seeded on first backend boot. Treat them as known credentials and change the passwords before going to production.

Phone	Password	Role
+256787959715	Trucaller@Admin2024!	SUPER_ADMIN
+256751159472	Trucaller@Admin2024!	SUPER_ADMIN

Admin login endpoint: POST <https://trucaller-backend-sh3t.onrender.com/api/admin/login>

Body: { "phoneNumber": "+256787959715", "password": "Trucaller@Admin2024!" }

End of document

Generated by Claude Code · June 10, 2026